

< ↻ ☆ Google AI Studio: Server-Side Data Persistence After User-Initiated Deletion (Non-Compliant Data Lifecycle Behavior)

+1

Hotlists (1)

Unmark Duplicate

🔔

⋮

Comments (6)

Dependencies (0)

Duplicates (0)

Blocking (0)

Resources (8)

Duplicate of 1467

Customer Issue

P4

+ Add Hotlist

 STATUS UPDATE No update yet.

 DESCRIPTION bu...@google.com created issue on behalf of gabor_gabor@freemail.hu #1

Sep 14, 2026 08:28AM

⋮

Summary: Google AI Studio: Server-Side Data Persistence After User-Initiated Deletion (Non-Compliant Data Lifecycle Behavior)

Program: AI VRP

URL: <https://aistudio.google.com/>

Vulnerability type: Sensitive data exposure

Details

Title Google AI Studio: Server-Side Data Persistence After User-Initiated Deletion (Non-Compliant Data Lifecycle Behavior)

Description This report documents a non-compliant backend data lifecycle behavior in Google AI Studio, where user-initiated deletion does not trigger server-side data purging, resulting in continued availability of personal data (prompts, conversation context, token history) after UI deletion and Google Drive Trash emptying.

This is not a UI bug, not a Drive issue, and not a “stateless vs. saved chat misunderstanding”. It is a backend persistence defect in the Interactions API data lifecycle.

Critical Distinction (cannot be dismissed as “intended behavior”) Google AI Studio exposes two fundamentally different chat types:

Temporary chats (stateless) – no Drive file, no persistence.

Saved chats (stateful) – stored as JSON pointers in Drive, backed by server-side state.

The defect affects saved chats, where the UI claims “Delete = permanent removal”, but the backend retains full conversation state even after:

deleting the JSON pointer,

emptying Drive Trash,

waiting multiple days or weeks,

restoring the pointer via Google’s official recovery tool.

This cannot be explained by:

“stateless architecture” (saved chats are stateful),

Reporter  gabor_gabor@freemail.hu

Type  Customer Issue

Priority P4

Severity S4

Status Duplicate of 1467

Access Default access View

Expanded Access?

Assignee

Verifier

Collaborators  ^

CC  ^
gabor_gabor@freemail.hu
wo...@google.com
Un-CC me

Code Changes --

Pending Code Changes --

Disclosure information --

Reporter e-mail --

Requested charity --

Found In --

Targeted To --

Comment added.

×

“disaster recovery” (DR systems cannot restore individual user JSON pointers),

“server-side logging” (logs cannot reconstruct full conversation state),

“retention window” (retention contradicts the UI’s “permanent deletion” claim).

These explanations are logically incompatible with the observed behavior.

Technical Summary When the user deletes a saved chat:

The UI removes the JSON pointer (Drive.trash).

No DELETE request is sent to Interactions API.

No cascade delete occurs.

The backend retains the full conversation state indefinitely.

Restoring the JSON pointer instantly reactivates the entire chat session.

This demonstrates that the deletion mechanism is incomplete and fails to propagate to backend storage systems.

Expected Behavior After deleting the JSON pointer and emptying Drive Trash:

The backend session associated with interaction_id must be hard-deleted.

Restoring the JSON pointer must result in:

404 Not Found,

or corrupted / empty state,

or non-resumable session.

This is the only behavior consistent with:

the UI’s “permanent deletion” wording,

standard cloud cascade-delete patterns,

Interactions API documentation (TTL auto-purge),

user expectations,

data lifecycle compliance.

Actual Behavior Restoring the deleted JSON pointer via Google’s official Drive File Recovery tool:

instantly reloads the full chat,

with 100% of conversation memory,

full context window,

full token history,

full backend state.

This proves that the backend never purged the data.

Steps to Reproduce Create a multi-turn saved chat in Google AI Studio.

Delete the chat via UI.

Verified In

--

In Prod



Comment added.



Empty Google Drive Trash.

Wait several days or weeks.

Use Google Drive File Recovery to restore the JSON pointer.

Open the restored file in AI Studio.

Observe full backend state restoration.

Why This Cannot Be Closed as “Won’t Fix / Obsolete / Intended Behavior”

1. Not a UI issue The defect is in backend data lifecycle, not UI.
2. Not a Drive issue Drive only stores the pointer. The backend stores the actual conversation.
3. Not a temp chat misunderstanding Temporary chats do not use Drive. Saved chats do. The defect affects saved chats only.
4. Not disaster recovery DR systems cannot restore individual user JSON pointers.
5. Not server-side logging Logs cannot reconstruct full conversation state.
6. Not retention window behavior Retention contradicts the UI’s “permanent deletion” claim.
7. Not obsolete The defect is present in current production systems.
8. Not “intended behavior” If intended, the UI wording (“permanent deletion”, “cannot be restored”) is misleading.

Evidence video:

<https://youtu.be/k6YHhDpnbXk>

<https://youtu.be/LBQfNbPCxQw>

Attack scenario

Impact Analysis This defect directly affects the integrity of user data lifecycle management across Google AI Studio and Google Drive, creating a multi-layered impact that cannot be dismissed as UI behavior, retention policy, or disaster-recovery side-effects.

1. User Trust & Misrepresentation The UI explicitly states “permanent deletion” and “cannot be restored”. However, the backend retains full conversation state indefinitely. This creates a misleading user experience where users believe their data is erased while Google continues to store and process it.

This is not a cosmetic issue; it is a misrepresentation of actual data handling.

2. Backend Data Persistence Beyond User Intent The defect causes server-side personal data (prompts, conversation context, token history) to persist after explicit user deletion.

This contradicts:

the Interactions API TTL specification,

standard cascade-delete behavior,

user expectations,

documented privacy guarantees.

This is a backend lifecycle failure, not a UI bug.

3. Legal & Compliance Exposure Because the backend retains personal data after deletion:

Comment added.



users cannot exercise their right to erasure,
data remains accessible and re-processable,
the system violates the principle of “indokolatlan késedelem nélküli törlés”.
This creates GDPR Article 17 exposure for Google.

This cannot be categorized as “intended behavior” without contradicting the UI wording and the API documentation.

4. Security & Risk Surface Expansion Retaining deleted conversation states increases:

the attack surface,
the persistence of sensitive prompts,
the risk of unauthorized access via restored pointers,
the risk of internal data leakage.

A deleted chat should not be recoverable by simply restoring a JSON pointer.

This is a security-relevant defect, not a UX issue.

5. Architectural Inconsistency The defect reveals a fundamental inconsistency between:

Google Drive’s file lifecycle,
AI Studio’s UI deletion semantics,
Interactions API’s backend retention behavior.

This inconsistency breaks the expected contract:

“Deleting the saved chat removes both the pointer and the backend state.”

Instead, only the pointer is removed.

This is a structural architecture flaw, not an obsolete feature.

6. Reproducibility & Severity The issue is:

reproducible across multiple accounts,
reproducible across multiple weeks,
reproducible with official Google tools,
reproducible without any special configuration.

Severity is High, because:

personal data persists after deletion,
backend state remains accessible,
the system contradicts its own documentation,
users are misled about data lifecycle.

The ban applied to my account is invalid.

This action was executed entirely by an automated VRP bot without any human review, and without any investigation of the submitted evidence, and without any evaluation of the actual technical issue.

Comment added

The bot is not authorized to issue permanent exclusions for reports that fall outside classical vulnerability categories (XSS, RCE, SQLi, sandbox escapes). My report documents a backend data-lifecycle defect involving server-side retention of user-deleted personal data. This is a compliance-relevant issue, not a Code of Conduct violation.

The “Won’t Fix (Intended Behavior)” label and the permanent ban were generated automatically and do not constitute a legitimate or valid enforcement action.

The automated exclusion prevents the GDPR Article 17 erasure-related complaint from being properly reviewed. This makes the enforcement action procedurally invalid.

I request reopening of the ticket and human review of both the report and the automated ban. If Google refuses to provide human review, the matter will be escalated to the appropriate data-protection authorities (NAIH / DPC / EDPB), as the VRP bot is obstructing a legally protected complaint process.

Report Analysis

Note: The feedback below was generated as part of an automated analysis of the submitted report. It is *NOT* part of the report that was submitted by the user.

Out of Scope

The report is out of scope for the selected VRP. Please review our program rules.

COMMENTS

All comments ▼

↓ Oldest first



sp...@google.com <sp...@google.com> [#2](#)

Sep 14, 2026 08:28AM ⋮

NOTE: This is an automatically generated email

Hi! Many thanks for sharing your report.

This email confirms we've received your message. We'll investigate the issue you've reported and get back to you once we have an update. In the meantime, you might want to take a look at the [list of frequently asked questions about Google Bug Hunters](#).

Also, if you have not already done so, create a profile on [the Google Bughunters site](#) if you'd like us to publicly recognize your contribution:

- [Leaderboard](#) – You'll be added here if we issue a reward for your report.
- [Honorable Mentions](#) – You'll be added here if you are not in the Hall of Fame, but we file a security vulnerability bug based on your report.

Note that we only act on reports concerning vulnerabilities or technical security problems in one of our products. This is not the correct channel if you need to resolve a problem with your account, or want to report non-security bugs or suggest a new product feature.

Cheers,
Google Security Bot

[Follow us](#) on Twitter!



gabor_gabor@freemail.hu <gabor_gabor@freemail.hu> [#3](#)

Comment added.

✕
Sep 14, 2026 08:30AM ⋮

The automated ban applied to my previous account was invalid, because it was issued without human review and without any evaluation of the technical evidence provided.

This report documents a backend data-lifecycle defect involving server-side retention of user-deleted personal data. This is a compliance-relevant issue, not a Code of Conduct violation.

The VRP bot is not capable of assessing backend data-lifecycle defects, therefore the "Won't Fix (Intended Behavior)" label cannot be considered a legitimate decision.

I request human review of this report.

The automated enforcement action prevents proper handling of an erasure-related complaint, and therefore requires human intervention.



sp...@google.com <sp...@google.com> [#4](#)

Sep 14, 2026 08:33AM ⋮

Status: Duplicate of [1467](#).

Hi! We've analyzed your report and want to let you know that **it is a duplicate of an existing bug** that we've already received. For this reason, we're closing this issue.

Unfortunately, this also excludes your report from our reward program – duplicate submissions don't qualify for reward or credit. Best of luck in your future bug hunting!

Thanks again for your report and time,
Google Security Bot



gabor_gabor@freemail.hu <gabor_gabor@freemail.hu> [#5](#)

Sep 14, 2026 08:42AM ⋮

I will not tolerate this issue being ignored.

The handling of user-deleted personal data described in this report has direct legal implications and will proceed through civil legal channels if it is not properly reviewed.

This is not a threat — it is a clear statement of the legal path that follows when server-side retention contradicts documented deletion behavior.

I request human review of this ticket and expect a response within a reasonable timeframe before further legal action is taken.



gabor_gabor@freemail.hu <gabor_gabor@freemail.hu> [#6](#)

Sep 14, 2026 08:47AM ⋮

A jó bűdös kurva anyáttokkal játszatok, olyan pert akasztok a nyakatokba ti gecik, hogy arról koldultok. Pár órát várok a mai nap. Ha nem írtok semmit, akkor beadom a polgári pert nemsokára. Anyáttokkal szórakoztatok ti gecik!!!! Azt hiszitek hülye vagyok???? Itt van az egyik ajánlott levél, amit aláírtatok Mountain View-ban májusban, nézegessétek tetvek, feltöltöm ide ti szarevő gecik!!!! Majd a bíróságon tagadhatjátok, és ezt a csalást is. Tényleg dupla jegy? Ja igen, mert azt is én adtam be ti fasszopók!

 **20260602_164036.jpg**



908 KB [View](#) [Download](#) 

Comment added.

